

Báo cáo kiểm toán AI — MSSV 23127326

Khai báo

Tôi sử dụng công cụ AI cho các công việc: trích xuất yêu cầu, phân tích contract và rủi ro, soạn test case, hỗ trợ audit từng dòng, triển khai fixture/Postman/CI, đối soát kết quả và cấu trúc tài liệu. Sinh viên chịu trách nhiệm về oracle cuối, bản sửa, thực thi và quyết định lỗi.

Nhật ký tương tác

Thời gian AI-001–AI-004 được giữ từ commit ghi nhận output lần đầu. Output có cấu trúc đầy đủ nằm trong `test-cases/23127326.json`; phần tóm tắt này không thay thế output đó. Mapping nguồn trong catalogue là: AI-001 = contract normalization; AI-002 = 40 case FR-04; AI-003 = 45 case FR-10; AI-004 = 40 case FR-19. Phần audit, sửa test case và bổ sung 15 case HUMAN được sinh viên thực hiện thủ công.

Lần tương tác AI-001

Tên công cụ AI: Codex

Ngày và giờ: 2026-08-31; batch ghi nhận lúc 23:31:15 +07:00

Prompt của bạn: Trích xuất contract endpoint FR-04, FR-10 và FR-19 từ `api_specification.md` và SRS chuẩn tắc. Liệt kê actor, input, output, role, đồ thị trạng thái và quy tắc SEC liên quan. Đánh dấu giả định schema/status chưa được quy định.

Kết quả đầu ra của AI: Danh mục chuẩn hóa cho GET/PUT `/api/users/me`, endpoint trạng thái đơn của Admin/User và endpoint liệt kê/xóa user; actor, giả định status và ánh xạ SEC-01–SEC-07. AI chỉ ra SEC-07 thuộc FR-03 và FR-19 không có endpoint cập nhật role.

Quyết định của sinh viên: Chấp nhận danh mục endpoint; ghi rõ SEC-07 là N/A và không cho phép bịa endpoint.

Lần tương tác AI-002

Tên công cụ AI: Codex

Ngày và giờ: 2026-08-31; batch ghi nhận lúc 23:31:15 +07:00

Prompt của bạn: Với FR-04, tạo ít nhất 40 API test case khác nhau. Phân hoạch phone/name/address; bao phủ xác thực, identity binding, mass assignment, trường nhạy cảm, output an toàn XSS và response schema chính xác. Gồm precondition, data, kết quả mong đợi, cleanup và traceability.

Kết quả đầu ra của AI: 40 dòng ứng viên FR-04 có cấu trúc, bao phủ xác thực, biên miền, schema, trường nhạy cảm và bảo mật. ID và bản sửa cuối là FR04-001-FR04-040 trong catalogue JSON; các dòng này mang nguồn AI-002.

Quyết định của sinh viên: Viết lại fixture chung và status thay thế thành setup cô lập, một status nguyên chính xác và postcondition; giữ 40 case là VALID sau khi sửa.

Lần tương tác AI-003

Tên công cụ AI: Codex

Ngày và giờ: 2026-08-31; batch ghi nhận lúc 23:31:15 +07:00

Prompt của bạn: Với FR-10, tạo ma trận chuyển trạng thái 5x5 đầy đủ, cùng case hủy, ownership, role, replay, status sai, terminal state và schema. Không bịa endpoint.

Kết quả đầu ra của AI: 45 dòng ứng viên FR-10 chứa mọi cặp source/destination và biến thể bảo mật/schema (FR10-001-FR10-045); các dòng này mang nguồn AI-003.

Quyết định của sinh viên: Gắn mỗi transition với fixture order riêng, xác minh đồ thị trạng thái chuẩn tắc và thêm GET postcondition trước khi gán VALID.

Lần tương tác AI-004

Tên công cụ AI: Codex

Ngày và giờ: 2026-08-31; batch ghi nhận lúc 23:31:15 +07:00

Prompt của bạn: Với FR-19, tạo ít nhất 40 case chỉ cho list/delete. Bao phủ phân quyền Admin, IDOR, self-delete, ID sai, payload SQL injection, privacy và schema. Đánh dấu ý tưởng cập nhật role là ngoài contract.

Kết quả đầu ra của AI: 40 case list/delete (FR19-001-FR19-040) với ID âm tính, role, privacy và ý tưởng postcondition; các dòng này mang nguồn AI-004.

Quyết định của sinh viên: Loại ý tưởng không có endpoint, cấp user dùng một lần cho case phá hủy và đặt self-delete cuối; 40 dòng cuối đều VALID.

Kiểm toán và mở rộng do sinh viên thực hiện

Sau bốn interaction tạo ứng viên, sinh viên tự audit từng dòng theo ba nhãn VALID/INVALID/INCOMPLETE, tự sửa các case chưa đạt, khử trùng và bổ sung 15 case HUMAN (5 case cho mỗi feature). Bản ghi hiện có timestamp batch chung; không có log riêng đủ tin cậy để gán thời gian khác cho từng interaction. Sinh viên cũng tự thực thi Newman, phân loại lỗi, kiểm tra bằng chứng GitHub/CI và hoàn thiện package.

Thống kê output

Nguồn output	FR-04	FR-10	FR-19	Tổng
AI tạo, sinh viên audit	40	45	40	125
Sinh viên bổ sung sau audit	5	5	5	15
VALID và đã thực thi cuối	45	50	45	140

Mỗi dòng có AI source, Audit label, Audit reason, Corrected version; dòng HUMAN có thêm Why AI missed. Không có output AI thô nào bị trình bày như nội dung do sinh viên tự tạo.

Ma trận ánh xạ SEC

Yêu cầu	Test case/nhóm minh chứng	Phạm vi
SEC-01	FR04-010; FR19 list/schema và injection	Lộ dữ liệu nhạy cảm, privacy, injection
SEC-02	Các case thiếu/sai/stale token ở cả FR04, FR10, FR19	Authentication
SEC-03	FR10-034, FR10-047; FR19-004, FR19-029, FR19-031, FR19-041	Authorization/admin-only
SEC-04	FR04 XSS cases và human extensions	API lưu/round-trip dữ liệu; escaping UI ngoài phạm vi
SEC-05	FR10 state-invariant cases; FR19 SQL-injection cases	Input/injection và integrity
SEC-06	FR04-033, FR04-034, FR04-045	Protected role/mass assignment
SEC-07	N/A	Chỉ áp dụng flow OTP reset-password của FR-03, không thuộc 3 feature đã chọn